DOCUMENTACION DE SISTEMA

RootCause Bitcoin Defense

10 · Configuración

Version analizada 0.3.0 · commit acdf4dd · generado el 2026-08-27
Documento 10 de la serie · fuente: docs/system-documentation/10-configuration.md

Contenido

1 · Cómo se configura el sistema
2 · Variables de entorno, en detalle
3 · Cómo se procesan los valores
4 · Diferencias entre entornos
5 · Configuración en la edición de Windows
6 · Archivos de configuración de dominio
7 · Banderas de funcionalidad
8 · Configuración sensible
9 · Verificar la configuración efectiva
10 · Consecuencias de las configuraciones más peligrosas

Cada variable, cada archivo de configuración y qué pasa exactamente cuando se ponen mal.

> **Ningún valor de este documento es un secreto real.** Donde haría falta una clave se usa un marcador entre ángulos. Si encuentras un secreto real en cualquier archivo de este repositorio, trátalo como comprometido y **rótalo**: borrarlo del árbol no lo borra del histórico de git.

---

1 · Cómo se configura el sistema

Mecanismo	¿Se usa?	Nota
Variables de entorno del proceso	[OK] **Sí**, es el único mecanismo de runtime	Leídas una vez en `loadConfig()`
Archivo `.env`	[FALLO] **No.** El sistema no lo lee	`.env.example` es solo una plantilla para copiar valores a mano
Argumentos de línea de comandos	[FALLO] No, para el servidor	Sí para los scripts de auditoría
Archivos JSON en `config/`	[OK] Sí, para datos de dominio	Avisos, política, catálogo y exenciones
`config.cmd` del perfil de usuario	[OK] Sí, en la edición de Windows	Lo carga el lanzador con `call`

> AVISO: **Confusión frecuente:** `.env.example` parece indicar que existe carga de `.env`, y no la hay. No hay ninguna llamada a `dotenv` ni equivalente — sería una dependencia. Es una plantilla documental. Anotado en `15-risks-and-technical-debt.md`.

2 · Variables de entorno, en detalle

2.1 · Red y modo

Variable	Tipo	Defecto	Rango	Consecuencia de configurarla mal
`HOST`	cadena	`127.0.0.1`	—	[FALLO] Fuera de loopback expone el panel **sin autenticación**. Dispara `BTC-OPSEC-001` crítico
`PORT`	entero	`8787`	0–65535	`0` deja que el sistema elija. Un valor no numérico cae a 8787
`DEMO_MODE`	booleano	`true`	`true`/`false`	[ATENCION] **Solo `"true"` literal es verdadero.** `1`, `yes` o `sí` significan `false` y activan la persistencia
`ROOTCAUSE_CONTAINERIZED`	booleano	autodetectado	`true`/`false`	Forzar `false` en un contenedor convierte `BTC-OPSEC-001` en crítico; forzar `true` fuera lo suaviza indebidamente
`ROOTCAUSE_OPEN_BROWSER`	`"1"`	sin definir	—	Solo abre navegador si vale exactamente `"1"` **y** el bind es loopback

2.2 · Persistencia

Variable	Tipo	Defecto	Consecuencia de configurarla mal
`ROOTCAUSE_DATA_KEY`	32 bytes en hex o base64	vacío	[FALLO] Ausente con `DEMO_MODE=false`: **el arranque falla**. Débil: `BTC-OPSEC-003`. **Perdida: los datos son irrecuperables**
`DATA_DIR`	ruta	`./data`	Una ruta sin permisos de escritura hace fallar el primer `save()`

Ejemplo de generación y uso, con marcador en lugar del valor:

```
node scripts/generate-key.js
export DEMO_MODE=false
export ROOTCAUSE_DATA_KEY="<pega-aqui-el-valor-generado>"
node src/server.js
```

2.3 · Bitcoin Core

Variable	Tipo	Defecto	Consecuencia de configurarla mal
`BITCOIN_RPC_URL`	URL	`http://127.0.0.1:8332`	[FALLO] Con credenciales incrustadas: **lanza al construir el cliente**. Fuera de loopback sin permiso: lanza
`BITCOIN_RPC_COOKIE_FILE`	ruta	vacío	Ruta inexistente: cada llamada falla y `snapshot()` devuelve `connected: false`
`BITCOIN_RPC_USER`	cadena	vacío	[ATENCION] Junto con la contraseña y sin cookie, dispara `BTC-OPSEC-005`
`BITCOIN_RPC_PASSWORD`	cadena	vacío	Ídem. **Acaba en el entorno del proceso y posiblemente en el historial de shell**
`ALLOW_REMOTE_RPC`	booleano	`false`	[FALLO] `true` permite un nodo remoto. Dispara `BTC-OPSEC-004` alto

Variable	Tipo	Defecto	Consecuencia de configurarla mal
`BITCOIN_RPC_TIMEOUT_MS`	entero	`5000`	Rango 500–60000. Muy bajo: falsos `BTC-NODE-001`. Muy alto: el watchtower se apila

2.4 · Vigilancia

Variable	Tipo	Defecto	Consecuencia
`WATCHTOWER_ENABLED`	booleano	`false`	[ATENCION] Apagado con wallets de alto valor: `BTC-OPSEC-006`. Encendido sin nodo: un `BTC-NODE-001` cada tick
`WATCHTOWER_INTERVAL_MS`	entero	`15000`	Rango 5000–3600000. Por debajo del mínimo se recorta a 5 s

2.5 · Límites y umbrales

Variable	Tipo	Defecto	Rango	Consecuencia
`REQUEST_BODY_LIMIT_BYTES`	entero	`65536`	1024–1048576	Al máximo dispara `BTC-OPSEC-007`
`RATE_LIMIT_PER_MINUTE`	entero	`120`	10–10000	≥ 5000 dispara `BTC-OPSEC-007`
`HIGH_VALUE_THRESHOLD_SATS`	entero	`10000000`	1–`MAX_SAFE_INTEGER`	[FALLO] **Cambia qué se considera alto valor**, y con ello si `BTC-CUSTODY-001` dispara. Subirlo mucho silencia la regla

---

3 · Cómo se procesan los valores

Comprender esto evita sorpresas:

Situación	Comportamiento	¿Avisa?
Variable ausente	Se usa el valor por defecto	No
Cadena vacía	Se usa el valor por defecto	No
Booleano distinto de `"true"`	Se interpreta como `false`	**No**
Entero no numérico	Se usa el valor por defecto	**No**
Entero por debajo del mínimo	**Se recorta al mínimo**	**No**
Entero por encima del máximo	**Se recorta al máximo**	**No**
`ROOTCAUSE_DATA_KEY` que no decodifica a 32 bytes	**Lanza**	**Sí**
`BITCOIN_RPC_URL` inválida o prohibida	**Lanza al construir el cliente**	**Sí**
`DEMO_MODE=false` sin clave	**Lanza al arrancar**	**Sí**

> [ATENCION] **Las siete primeras filas son silenciosas.** `PORT=ochenta` arranca en 8787 sin decir nada, y `RATE_LIMIT_PER_MINUTE=5` aplica 10. Es tolerante a propósito —el sistema nunca se niega a arrancar por una errata menor— pero significa que hay que comprobar la configuración efectiva, no la que se creía haber puesto. **Cómo**

> **comprobarla:** `GET /api/posture` devuelve el bloque `deployment` con los valores realmente en uso.

---

4 · Diferencias entre entornos

Ajuste	Desarrollo	Pruebas y CI	Producción de escritorio	Contenedor
`HOST`	`127.0.0.1`	`127.0.0.1`	`127.0.0.1`	`0.0.0.0` **dentro** del contenedor
`PORT`	`8787`	`0` (libre)	`8787`	`8787`, publicado en loopback
`DEMO_MODE`	`true`	`true`	`false` recomendado	`true` en el compose de ejemplo
`ROOTCAUSE_DATA_KEY`	Sin definir	Sin definir	**Obligatoria**	Obligatoria si se desactiva la demo
`DATA_DIR`	`./data`	—	`%LOCALAPPDATA%\RootCause\bitcoin-defense\data`	`/var/lib/rootcause-bitcoin-defense`
`WATCHTOWER_ENABLED`	`false`	`false`	Según haya nodo	`false`
`ROOTCAUSE_OPEN_BROWSER`	Sin definir	`0` explícito en CI	`1`, lo fija el lanzador	Sin definir

> En CI se fija `ROOTCAUSE_OPEN_BROWSER=0` de forma explícita para que la prueba de humo del lanzador no intente abrir un navegador en un runner sin escritorio.

---

5 · Configuración en la edición de Windows

El lanzador `packaging/windows/launcher/RootCause-Bitcoin-Defense.cmd` crea el directorio del perfil y carga la configuración del usuario si existe:

Elemento	Ruta
Directorio base	`%LOCALAPPDATA%\RootCause\bitcoin-defense`
Configuración	`%LOCALAPPDATA%\RootCause\bitcoin-defense\config.cmd`
Datos	`%LOCALAPPDATA%\RootCause\bitcoin-defense\data`

Contenido típico de `config.cmd`, con marcador en lugar de la clave:

```
set "DEMO_MODE=false"
set "ROOTCAUSE_DATA_KEY=<pega-aqui-el-valor-generado>"
set "BITCOIN_RPC_COOKIE_FILE=%APPDATA%\Bitcoin\.cookie"
set "WATCHTOWER_ENABLED=true"
```

Si `DEMO_MODE=false` y no hay clave, el lanzador **se detiene con un mensaje explicativo** antes de arrancar Node, indicando qué archivo crear y con qué línea.

Lo importante: el archivo de configuración vive en el perfil del usuario, no en la carpeta del programa. Así la clave no se distribuye con el paquete, no se pierde al actualizar y no acaba en una copia de seguridad del directorio de instalación.

---

6 · Archivos de configuración de dominio

6.1 · `config/advisories.json`

Array de avisos. Estructura de cada entrada:

Campo	Tipo	Obligatorio	Uso
`id`	cadena	Sí	Aparece en la evidencia del hallazgo
`title`, `summary`	cadena	Sí	Panel de inteligencia
`severity`	enum	Sí	Presentación
`status`	cadena	Sí	`active`, `monitoring`… informativo
`publishedAt`	ISO-8601	Sí	Respaldo para `BTC-INTEL-001`
`verifiedAt`	ISO-8601	**Sí en la práctica**	**Es lo que mide `BTC-INTEL-001`**
`vendor`	cadena	Sí	Debe coincidir con `signers[].vendor`
`affected[]`	array	Sí	Rangos; **array vacío = no genera `BTC-KEY-001`**
`affected[].models`	array	Sí	Debe coincidir con `signers[].model`
`affected[].track`	cadena	No	Si falta, coincide con cualquier canal
`affected[].minInclusive`, `maxInclusive`, `minExclusive`, `maxExclusive`	cadena	No	**Todos opcionales; sin ninguno, el rango alcanza todas las versiones**
`mitigation[]`	array	Sí	Se copia tal cual a `remediation` del hallazgo
`sources[]`	array	Sí	`label` y `url`; la URL pasa por `safeUrl` en el panel

> **Cuidado al editar:** `vendor` y `models` se comparan normalizados —minúsculas y sin espacios extremos— pero **deben ser el mismo nombre** que el operador escriba al registrar el firmante. `"Coldcard"` y `"COLDCARD"` casan; `"Coinkite"` y `"COLDCARD"` no. Y actualizar `verifiedAt` sin haber contrastado de verdad con la fuente oficial silencia `BTC-INTEL-001` sin que la inteligencia haya mejorado. Es la forma más fácil de convertir el panel en una mentira.

6.2 · `config/policies.json`

Campo	Uso real en el código
`advisoryMaxAgeDays`	[OK] Lo lee `DefenseService.evaluate()`; **no está en el archivo hoy**, así que se aplica el defecto de 30
`highValueThresholdSats`	[ATENCION] **Informativo.** El valor efectivo viene de `HIGH_VALUE_THRESHOLD_SATS`
`humanApprovalRequired[]`	[OK] La etapa 14 de la auditoría exige que contenga `broadcast_transaction`

Campo	Uso real en el código
`forbiddenActions[]`, `automaticActions[]`, `minimumHighValueQuorum`, `requireIndependentVendorsForHighValue`, `blockUnknownFirmware`, `blockAffectedWalletDeposits`	[ATENCION] **Declarativos.** Documentan la política; **ninguna regla los lee**

> [ATENCION] Buena parte de `policies.json` es documentación de intención, no configuración efectiva. Es honesto en tanto describe lo que el producto hace por otras vías, pero **cambiar `blockUnknownFirmware` a `false` no desactiva `BTC-KEY-002`**. Registrado en `15-risks-and-technical-debt.md`.

6.3 · `config/rules-catalog.json`

Fuente única de `docs/reglas/` y `landing/reglas.html`. Cada ficha debe declarar `code`, `title`, `severity`, `severityNote`, `entity`, `trigger`, `threshold`, `meaning`, `rootCause`, `evidence[]`, `remediation[]`, `notMeaning[]`, `verify`, `source` y opcionalmente `falsePositive` y `related[]`.

`test/rules-catalog.test.js` comprueba seis invariantes, incluido que **todo código del motor tenga ficha y toda ficha corresponda a una regla real**. Añadir una regla sin documentarla rompe el build.

6.4 · `config/secret-scan-allow.json`

Exenciones del escáner de secretos. Cada una declara `path`, `id` y `reason`.

Hoy contiene una sola: la muestra de la wordlist BIP-39 dentro del propio detector, que si no se detectaría a sí mismo. **El informe cuenta las exenciones usadas y denuncia las que ya no hacen falta**, porque una exención de más tapa hallazgos futuros.

---

7 · Banderas de funcionalidad

No hay sistema de *feature flags*. Lo más parecido son cuatro variables que activan o desactivan comportamiento:

Variable	Efecto
`DEMO_MODE`	Memoria frente a persistencia cifrada
`WATCHTOWER_ENABLED`	Vigilancia periódica
`ALLOW_REMOTE_RPC`	Destinos RPC no loopback
`ROOTCAUSE_OPEN_BROWSER`	Apertura automática del panel

Las cuatro están **apagadas o en el valor conservador por defecto**, y `check-security-claims.js` lo verifica en cada build.

---

8 · Configuración sensible

Elemento	Sensibilidad	Dónde debe vivir	Dónde no
`ROOTCAUSE_DATA_KEY`	**Máxima**	Gestor de contraseñas; `config.cmd` en el perfil	Nunca junto al archivo de datos, nunca en git
`BITCOIN_RPC_PASSWORD`	Alta	Preferible no usarla: usar la cookie	Nunca en git ni en la URL

Elemento	Sensibilidad	Dónde debe vivir	Dónde no
`BITCOIN_RPC_COOKIE_FILE`	Media	Ruta al archivo del nodo	—
Contenido de `data/`	Alta	`%LOCALAPPDATA%` o `DATA_DIR`	`.gitignore` ya lo excluye

Protecciones existentes:

Protección	Dónde
`.env`, `data/*` y `SECURITY_AUDIT_BITCOIN_*.md` en `.gitignore`	Raíz
Detección de `xprv`/PEM en todo archivo de texto	`scripts/validate-repo.js`
10 patrones de secreto sobre **todo el histórico de git**	`scripts/check-history-secrets.js`
`gitleaks` como capa genérica	`security-audit.yml`
Rutas prohibidas (`.env`, `.cookie`, `id_rsa`, `.p12`...)	`check-history-secrets.js`
El paquete de Windows rechaza incluir `data`, `.env` o `.git`	`build-portable.ps1`
Credenciales en la URL de RPC	`validateRpcUrl` lanza

---

9 · Verificar la configuración efectiva

```
curl -s http://127.0.0.1:8787/api/posture
```

Devuelve el bloque `deployment` con los valores en uso y los hallazgos de postura que esa configuración produce. Es la forma fiable de comprobar qué está aplicándose, frente a lo que se creía haber configurado.

Fuera del servidor:

```
node scripts/audit-bitcoin.js --stages=9,10,11
```

Ejecuta las tres etapas de instalación —postura, aislamiento del nodo y cifrado— con la configuración del proceso actual.

---

10 · Consecuencias de las configuraciones más peligrosas

Configuración	Qué se rompe exactamente
`HOST=0.0.0.0` fuera de contenedor	[FALLO] Cualquiera en la red ve el inventario, los saldos y los fabricantes, **y puede modificarlo**: no hay autenticación
`ALLOW_REMOTE_RPC=true`	[FALLO] Las credenciales RPC viajan por la red; Bitcoin Core desaconseja exponer RPC
`ROOTCAUSE_DATA_KEY` escrita a mano	[FALLO] El estado se cifra con una clave adivinable. `BTC-OPSEC-003` lo marca
`ROOTCAUSE_DATA_KEY` junto al archivo de datos	[FALLO] Cifrado inútil: quien tiene uno tiene el otro

Configuración	Qué se rompe exactamente
`HIGH_VALUE_THRESHOLD_SATS` muy alto	[ATENCION] **Silencia `BTC-CUSTODY-001` y `BTC-OPSEC-006`** sin que nada lo advierta
`DEMO_MODE=true` con inventario real	[ATENCION] Todo se pierde al cerrar. `BTC-OPSEC-002` lo marca
`RATE_LIMIT_PER_MINUTE=10000`	[ATENCION] `BTC-OPSEC-007`, y el mapa del limitador crece más deprisa
`WATCHTOWER_INTERVAL_MS` muy bajo con nodo lento	[ATENCION] Los ticks se saltan por la guarda `running`; no se acumulan, pero se pierden ciclos
`verifiedAt` actualizado sin contrastar	[FALLO] **Silencia `BTC-INTEL-001` sin mejorar la inteligencia.** El peor de todos, porque no deja rastro

---

Siguiente	
Análisis de seguridad completo	`11-security.md`
Volver al índice	`README.md`